

Базовий профіль безпеки (L1)

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
УПРАВЛІННЯ ДОСТУПОМ (АС)				
1	id-spe-ac-1		АС-1	Визначено персонал або ролі, на які поширюється політика контролю доступу: adminsecurity_officer Визначено персонал або ролі, на які поширюються процедури контролю доступу: adminsecurity_officer Визначено посадову особу, яка керуватиме політикою та процедурами контролю доступу: adminsecurity_officer Визначено частоту, з якою переглядається та оновлюється поточна політика контролю доступу: default_deny_ruleabac_rule_1 Визначено події, які вимагають перегляду та оновлення поточної політики контролю доступу: default_deny_ruleabac_rule_1 Визначено частоту, з якою переглядаються та оновлюються поточні процедури контролю доступу: 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
2	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2)		АС-2, АС-2(3), АС-2(5), АС-2(13)	Визначено передумови та критерії членства в групах і ролях; визначено атрибути (за необхідності) для кожного облікового запису; визначено персонал або ролі, необхідні для затвердження запитів на створення облікових записів; визначено політику, процедури, передумови та критерії створення, активації, зміни, деактивації та видалення облікових записів; визначено персонал або ролі, які мають бути повідомлені; визначено період часу, протягом якого адміністратори облікових записів повинні бути повідомлені про те, що облікові записи більше не потрібні; визначено термін, протягом якого необхідно повідомляти адміністраторів облікових записів про звільнення або переведення користувачів; визначено період часу, протягом якого необхідно повідомляти адміністраторів облікових записів про зміни у використанні системи або необхідність знати про зміни для окремої особи; визначено атрибути, необхідні для авторизації доступу до системи (за потреби); АС-02_ODP[10] АС-02a.[01] АС-02a.[02] АС-02b АС-02c АС-02d.01 АС-02d.02 АС-02d.03[01] АС-02d.03[02] АС-02e АС-02f.[01] АС-02f.[02] АС-02f.[03] АС-02f.[04] АС-02f.[05] АС-02g АС-02h.01 АС-02h.02 АС-02h.03 АС-02i.01 АС-02i.02 АС-02i.03 визначено періодичність перегляду облікових записів; визначено та задокументовано типи облікових записів, дозволених для використання в системі; визначено та задокументовано типи облікових записів, які заборонено використовувати в системі; призначені менеджери облікових записів; необхідні умови та критерії для членства в групах та ролях; визначено авторизованих користувачів системи; вказано приналежність до групи або ролі; для кожного облікового запису вказуються повноваження доступу (тобто привілеї); атрибути (за необхідності) вказуються для кожного облікового запису; для запитів на створення облікових записів потрібні схвалення від персоналу або ролей; облікові записи створюються відповідно до політики, процедур, передумов та критеріїв; облікові записи активуються відповідно до політики, процедур, передумов та критеріїв; облікові записи змінюються відповідно до політики, процедур, передумов та критеріїв; облікові записи деактивуються відповідно до політики, процедур, передумов та критеріїв; облікові записи видаляються відповідно до політики, процедур, передумов та критеріїв; контролюється використання облікових записів; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли облікові записи більше не потрібні; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли користувачі звільнені чи переведені; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли використовуються індивідуальні системи або наявні зміни, які потребують нових знань. доступ до системи здійснюється на підставі

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
3	ЗАБЕЗПЕЧЕННЯ ДОСТУПУ (АС-3)		АС-3	Затверджені повноваження на логічний доступ до інформації та ресурсів системи виконуються відповідно до чинних політик(правил) управління доступом: default_deny_ruleabac_rule_1
4	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ (АС-4)		АС-4	Затверджені повноваження застосовуються для контролю потоку інформації всередині системи та між підключеними системами на основі політики управління інформаційними потоками: default_deny_ruleabac_rule_1 Визначено політики управління інформаційними потоками всередині системи та між підключеними системами: default_deny_ruleabac_rule_1
5	РОЗМЕЖУВАННЯ ОБОВ'ЯЗКІВ (АС-5)		АС-5	
6	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ (АС-6)		АС-6, АС-6(1), АС-6(2), АС-6(5), АС-6(7), АС-6(9), АС-6(10)	Визначені особи або ролі з авторизованим доступом до функцій безпеки та інформації, що має відношення до безпеки: adminsecurity_officer Користувачі облікових записів (або ролей) системи з доступом до функцій безпеки або інформації, що стосується безпеки, повинні використовувати непривілейовані облікові записи або ролі під час доступу до незахищених функцій: adminsecurity_officer Привілейовані облікові записи в системі обмежено персонал або ролі: adminsecurity_officer Визначено персонал або ролі, яким мають бути обмежені привілейовані облікові записи в системі: adminsecurity_officer Повноваження, призначені ролям і класам, переглядаються з частотою для перевірки необхідності таких повноважень: 30 Визначено частоту перегляду повноважень, призначених ролям або класам користувачів: 30 Визначено ролі або класи користувачів, яким призначено повноваження : adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
7	НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ (АС-7)		АС-7	Застосовано обмеження на кількість послідовних неуспішних спроб входу користувача протягом періоду часу: 30 Визначається кількість послідовних неуспішних спроб входу користувача, дозволених протягом певного періоду часу: 30 Визначено період часу, яким обмежується кількість послідовних неуспішних спроб входу користувача: 30 Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {заблокувати обліковий запис або вузол на період часу; заблокувати обліковий запис або вузол до зняття адміністратором; затримати наступний запит на вхід за алгоритмом затримки; повідомити системного адміністратора; виконати іншу дію}: AES-256-GCM Період часу, на який буде заблоковано обліковий запис або вузол (якщо вибрано): 30 Визначено алгоритм затримки наступного запиту на вхід (якщо вибрано): AES-256-GCM Інша дія, яка буде виконана після перевищення максимальної кількості невдалих спроб (якщо вибрано): 3

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
8	id-spe-ac-8		АС-8	Визначається сповіщення або банер про використання системи, який система буде показувати користувачам перед наданням доступу до системи; визначено умови використання системи, які система відображатиме перед наданням подальшого доступу; повідомлення про використання системи відображається користувачам перед наданням доступу до системи, яке містить повідомлення про конфіденційність і безпеку, що відповідають чинним законам, нормативним документам, наказам, директивам, політикам, правилам, стандартам і керівним принципам; у повідомленні про використання системи зазначено, що користувачі отримують доступ до урядової системи; у повідомленні про використання системи зазначено, що використання системи може контролюватися, реєструватися та підлягати аудиту; у повідомленні про використання системи зазначено, що несанкціоноване використання системи заборонено і тягне за собою кримінальну та цивільну відповідальність; у повідомленні про використання системи зазначено, що використання системи означає згоду на моніторинг і запис дій; сповіщення або банер залишається на екрані до тих пір, поки користувачі не визнають умови використання та не приймуть явні дії для входу в систему або подальшого доступу до неї; для загальнодоступних систем інформація про використання системи умови відображається перед наданням подальшого доступу до загальнодоступної системи; для загальнодоступних систем відображаються будь-які посилання на моніторинг, запис або аудит, які узгоджуються з положеннями про конфіденційність таких систем, що зазвичай забороняють ці види діяльності; для загальнодоступних систем додається опис авторизованого використання системи: default_deny_ruleabac_rule_1
9	БЛОКУВАННЯ ПРИСТРОЮ (АС-11)		АС-11, АС-11(1)	Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {ініціювання блокування пристрою після періоду неактивності; вимога до користувача ініціювати блокування пристрою перед тим, як залишити систему без нагляду}: 30 Часовий проміжок бездіяльності, після якого ініціюється блокування пристрою (якщо вибрано): 30
10	Припинення сеансу (АС-12)		АС-12	Визначено умови або події, що вимагають припинення сеансу: loginlogoutfailed_attempt
11	ВІДДАЛЕНИЙ ДОСТУП (АС-17)		АС-17, АС-17(3), АС-17(4)	
12	БЕЗДРОТОВИЙ ДОСТУП (АС-18)		АС-18, АС-18(1), АС-18(3)	Бездротовий доступ до системи захищений за допомогою шифрування: AES-256-GCM
13	id-spe-ac-19		АС-19, АС-19(5)	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
14	ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ (АС-20)		АС-20, АС-20(1), АС-20(2)	Вибрано одне або більше з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {встановити умови та положення; визначити заходи захисту}: Визначено умови та положення, що відповідають довірчим відносинам, встановленим з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи (якщо вибрано): Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після перевірки виконання заходів безпеки та конфіденційності, зазначених у політиці безпеки та конфіденційності організації, а також планах безпеки та конфіденційності (якщо такі застосовуються): adminsecurity_officer Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після збереження погоджених угод про підключення або обробку системи з структурою організації, на якій розміщена зовнішня система: adminsecurity_officer Використання портативних пристроїв носіїв інформації уповноваженими особами обмежено у зовнішніх системах за допомогою обмеження : adminsecurity_officer Визначено обмеження на використання авторизованими особами портативних носіїв інформації у зовнішніх системах: adminsecurity_officer
15	ПУБЛІЧНО ДОСТУПНИЙ КОНТЕНТ (АС-22)		АС-22	Визначені особи уповноважені на розміщення інформації в загальнодоступній системі: adminsecurity_officer Уповноважені особи проходять навчання, щоб гарантувати, що загальнодоступна інформація не містить інформацію з обмеженим доступом: adminsecurity_officer Зміст у загальнодоступній системі перевіряється на наявність інформації з обмеженим доступом з частотою: 30 Визначено частоту, з якою слід переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом: 30
ОБІЗНАНІСТЬ ТА НАВЧАННЯ (АТ)				
16	id-spe-at-1		АТ-1	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
17	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ (АТ-2)		АТ-2, АТ-2(2), АТ-2(3)	Оновлюється зміст навчання грамотності та підвищення обізнаності з частотою: 30 Визначено періодичність проведення навчання грамотності з питань безпеки для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу: щорічно Визначено періодичність проведення навчання грамотності з питань конфіденційності для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу: щорічно Визначено події, які потребують навчання користувачів системи грамотності з питань безпеки: loginlogoutfailed_attempt Визначено частоту оновлення навчання грамотності та змісту обізнаності; АТ-02_ODP[07] визначено події після яких необхідне оновлення навчання грамотності та змісту обізнаності; АТ-02(a)[01][01] навчання з грамотності з питань безпеки надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; АТ-02(a)[01][02] навчання з грамотності з питань конфіденційності надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; АТ-02(a)[01][03] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання з безпеки з періодичністю після цього; АТ-02(a)[01][04] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання з конфіденційності з періодичністю після цього; АТ-02(a)[02][01] тренінги з грамотності з питань безпеки проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників), коли цього вимагають зміни в системі або після подій; АТ-02(a)[02][02] тренінги з грамотності з питань конфіденційності проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників), коли цього вимагають зміни в системі або після подій: loginlogoutfailed_attempt Визначено події, які потребують навчання користувачів системи грамотності з питань конфіденційності: loginlogoutfailed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
18	РОЛЬОВЕ НАВЧАННЯ (АТ-3)		АТ-3	Оновлюється вміст навчання на основі ролей з частотою: 30 Визначено ролі та обов'язки для тренінгів з безпеки на основі ролей: adminsecurity_officer Визначено ролі та обов'язки для тренінгів з конфіденційності на основі ролей: adminsecurity_officer Визначено частоту проведення тренінгів на основі ролей з безпеки та конфіденційності для призначеного персоналу після початкової підготовки: adminsecurity_officer Визначено частоту оновлення змісту навчання на основі ролей: 30 Визначено події, які потребують оновлення змісту навчання на основі ролей; АТ-03(а)[01][01] навчання з безпеки на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; АТ-03(а)[01][02] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; АТ-03(а)[01][03] навчання з безпеки на основі ролей проводиться для ролей та обов'язків з частотою після цього; АТ-03(а)[01][04] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків з частотою після цього; АТ-03(а)[02][01] навчання з питань безпеки на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі; АТ-03(а)[02][02] навчання з питань конфіденційності на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі: adminsecurity_officer
АУДИТ ТА ПІДЗВІТНІСТЬ (АУ)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
19	id-spc-au-1		AU-1	Розроблено та задокументовано політику аудиту та підзвітності: default_deny_ruleabac_rule_1 Політика аудиту та підзвітності доведена до персоналу або ролі: adminsecurity_officer Розроблені та задокументовані процедури аудиту та підзвітності, що сприяють впровадженню політики аудиту та підзвітності, а також відповідні заходи контролю аудиту та підзвітності: default_deny_ruleabac_rule_1 Посадова особа призначається для управління політикою та процедурами аудиту та підзвітності AU-01(c)[01][01] переглядається та оновлюється поточна політика аудиту та підзвітності з частотою; AU-01(c)[01][02] переглядається та оновлюється поточна політика аудиту та підзвітності після подій; AU-01(c)[02][01] переглядається та оновлюється поточні процедури аудиту та підзвітності з частотою; AU-01(c)[02][02] переглядається та оновлюється поточні процедури аудиту та підзвітності після подій: adminsecurity_officer Визначено персонал або ролі, до яких має бути доведена політика аудиту та підзвітності: adminsecurity_officer Визначено персонал або ролі, на які поширюються процедури аудиту та підзвітності: adminsecurity_officer Визначено посадову особу, яка управлятиме політикою та процедурами аудиту та підзвітності: adminsecurity_officer Визначено частоту, з якою переглядається та оновлюється поточна політика аудиту та підзвітності: default_deny_ruleabac_rule_1 Визначено події, які потребують перегляду та оновлення поточної політики аудиту та підзвітності: default_deny_ruleabac_rule_1 Визначено частоту, з якою переглядаються та оновлюються поточні процедури аудиту та підзвітності: 30 Визначено події, які потребують перегляду та оновлення поточної процедури аудиту та підзвітності: loginlogoutfailed_attempt
20	ПОДІЇ АУДИТУ (AU-2)		AU-2	Зазначені типи подій реєструються 02_ODP[03] частота або ситуація>; <AU-: щорічно Переглядаються та оновлюються типи подій, вибрані для реєстрації, частота. у системі: щорічно Визначено частоту або ситуацію, що вимагає проведення аудиту для кожної ідентифікованої події: loginlogoutfailed_attempt Частота перегляду та оновлення типів подій, обраних для журналювання: щорічно

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
21	ЗМІСТ ЗАПИСІВ АУДИТУ (AU-3)		AU-3, AU-3(1)	Записи аудиту містять інформацію, яка встановлює який тип події стався: loginlogoutfailed_attempt Записи аудиту містять інформацію, яка встановлює джерело події: loginlogoutfailed_attempt Записи аудиту містять інформацію, яка встановлює наслідки події: loginlogoutfailed_attempt Записи аудиту містять інформацію, яка встановлює результат події та ідентифікатор будь-яких осіб або суб'єктів, пов'язаних з подією: loginlogoutfailed_attempt
22	id-spe-au-5		AU-5	Персонал або ролі отримують сповіщення у разі збою процесу обробки даних аудиту періоду часу: adminsecurity_officer Додаткові дії виконуються у разі збою процесу обробки даних аудиту: loginlogoutfailed_attempt Визначено персонал або ролі, які отримують сповіщення про збої в процесі обробки даних аудиту : adminsecurity_officer Визначено період часу, протягом якого персонал або ролі отримують сповіщення про збої в процесі обробки даних аудиту: adminsecurity_officer Визначено додаткові дії, яких слід вжити у випадку збою в процесі обробки даних аудиту : loginlogoutfailed_attempt
23	ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ (AU-6)		AU-6, AU-6(3)	Записи аудиту системи переглядаються та аналізуються частота для виявлення ознак неналежної або незвичної діяльності та потенційного впливу неналежної або незвичної діяльності: щотижня Звіт аудиту відправляється персоналу або ролям: adminsecurity_officer Визначено частоту, з якою переглядаються та аналізуються записи аудиту системи: 30 Визначено персонал або ролі які отримують результати оглядів та аналізів системних записів: adminsecurity_officer
24	id-spe-au-7		AU-7	Забезпечено можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту: 30 Реалізовано можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту: 30
25	ПОЗНАЧКА ЧАСУ (AU-8)		AU-8	Внутрішній системний годинник використовується для створення позначок часу для записів аудиту: 30 Позначки часу застосовуються для записів аудиту, які відповідають деталізації вимірювання часу і які використовують всесвітній координований час, мають фіксоване місцеве зміщення місцевого часу від всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу: 30 Визначено деталізацію вимірювання часу для часових позначок записів аудиту: 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
26	ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ (AU-9)		AU-9, AU-9(4)	Персонал або ролі отримують сповіщення при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту: adminsecurity_officer Визначено персонал або ролі, які мають бути сповіщені при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту: adminsecurity_officer
27	ЗБЕРЕЖЕННЯ ЗАПИСІВ АУДИТУ (AU-11)		AU-11	Записи аудиту зберігаються впродовж період часу, щоб забезпечити підтримку розслідування (постфактум) інцидентів безпеки та конфіденційності, а також відповідати нормативним та вимогам організації щодо збереження даних аудиту: 30 Визначено період часу для зберігання записів аудиту, який узгоджується з політикою зберігання записів: default_deny_ruleabac_rule_1
28	ГЕНЕРАЦІЯ ДАНИХ АУДИТУ (AU-12)		AU-12	Персонал або ролі може/можуть вибирати типи подій, які будуть реєструватися певними компонентами системи; AU-12(с) згенеровано записи аудиту для типів подій, визначених у AU02_ODP[02], які включають вміст записів аудиту, визначений у AU03: adminsecurity_officer Визначено персонал або ролі, яким дозволено обирати типи подій, що мають реєструватися певними компонентами системи: adminsecurity_officer
ОЦІНЮВАННЯ, АВТОРИЗАЦІЯ ТА МОНІТОРИНГ (CA)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
29	id-spe-ca-1		CA-1	Розроблено та задокументовано політику оцінювання, авторизації та моніторингу: default_deny_ruleabac_rule_1 Політика оцінювання, авторизації та моніторингу поширюється серед персоналу або ролей: adminsecurity_officer Розроблені та задокументовані процедури оцінювання, авторизації та моніторингу, що сприяють впровадженню політики оцінювання, авторизації та моніторингу, а також пов'язані з ними засоби контролю оцінювання, авторизації та моніторингу: default_deny_ruleabac_rule_1 Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур оцінювання, авторизації та моніторингу; CA-01(c)[01][01] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу з частотою; CA-01(c)[01][02] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу після подій; CA-01(c)[02][01] переглядаються та оновлюються поточні процедури оцінки, авторизації та моніторингу з частотою; CA-01(c)[02][02] переглядаються та оновлюються поточні процедури оцінки, авторизації та моніторингу після подій; ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ: adminsecurity_officer Визначено персонал або ролі, серед яких має бути поширена політика оцінювання, авторизації та моніторингу: adminsecurity_officer Визначено персонал або ролі, серед яких мають бути поширені процедури оцінювання, авторизації та моніторингу: adminsecurity_officer Визначено посадову особу, яка управлятиме розробкою, документуванням і розповсюдженням політики та процедур оцінювання, авторизації та моніторингу: adminsecurity_officer Визначено частоту, з якою переглядається та оновлюється поточна політика оцінювання, авторизації та моніторингу: default_deny_ruleabac_rule_1 Визначено події, які потребують перегляду та оновлення поточної політики оцінки, авторизації та моніторингу: default_deny_ruleabac_rule_1 Визначено частоту, з якою переглядається та оновлюється поточні процедури оцінювання, авторизації та моніторингу: 30 Визначено події, які потребують перегляду та оновлення поточні процедури оцінки, авторизації та моніторингу: loginlogoutfailed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
30	ОЦІНЮВАННЯ (СА-2)		СА-2	Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи заходи захисту та посилені заходи, що підлягають оцінюванню. СА-02(b)(02) розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. СА-02(b)(03)(01) розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. СА-02(b)(03)(02) розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. СА-02(b)(03)(03) розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання: adminsecurity_officer Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. СА-02(b)(03)(01) розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. СА-02(b)(03)(02) розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. СА-02(b)(03)(03) розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання: adminsecurity_officer План оцінки заходів захисту розглядається та затверджується уповноваженою посадовою особою або призначеним представником перед проведенням оцінки: adminsecurity_officer Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до безпеки: щорічно Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до конфіденційності; СА-02(e) готується звіт оцінювання: щорічно Результати оцінювання з безпеки надаються особам або ролям. оцінювання , який документує результати: adminsecurity_officer Визначено частоту, з якою слід оцінювати засоби контролю в системі та середовищі її функціонування: 30 Визначені особи або ролі, яким мають бути надані результати оцінювання з безпеки: adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
31	ВЗАЄМОДІЯ СИСТЕМ (CA-3)		CA-3	Характеристики інтерфейсу задокументовані як частина кожної угоди про обмін: 30 Вимоги до безпеки задокументовані як частина кожної угоди про обмін: 30 Вимоги щодо конфіденційності задокументовані як частина кожної угоди про обмін: 30 Заходи захисту задокументовані як частина кожної угоди про обмін: 30 Відповідальність за кожну систему задокументована як частина кожної угоди про обмін: 30 Характер переданої інформації документується як частина кожної угоди про обмін: 30 Угоди переглядаються та оновлюються частота: щорічно Визначено частоту, з якою необхідно переглядати та оновлювати угоди: 30
32	id-spe-ca-5		CA-5	Розроблено план усунення недоліків та контрольні показники для системи, та задокументовано заплановані дії організації з коригування, спрямовані на усунення недоліків та зауважень, виявлених під час оцінки заходів захисту, а також на зменшення або усунення відомих вразливостей в системі: loginlogoutfailed_attempt Існуючий план оновлюється частота на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу: щорічно Визначено частоту оновлення чинного плану усунення недоліків та контрольних показників на основі результатів оцінювання заходів захисту, незалежних аудитів та постійного моніторингу: 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
33	БЕЗПЕРЕРВНИЙ МОНІТОРИНГ (СА-7)		СА-7	Безперервний моніторинг на рівні системи включає встановлені частоти для моніторингу ефективності заходів захисту: 30 Безперервний моніторинг на рівні системи включає встановлені частоти для оцінки ефективності заходів захисту: 30 Безперервний моніторинг на рівні системи включає в себе дії з реагування на результати аналізу інформації, пов'язаної з безпекою та приватністю: loginlogoutfailed_attempt Безперервний моніторинг на рівні системи включає повідомлення про статус безпеки системи для персоналу або ролей частота: adminsecurity_officer Безперервний моніторинг на рівні системи включає повідомлення про стан конфіденційності системи персоналу або ролям частота: adminsecurity_officer Визначено частоту, з якою слід моніторити ефективність заходів захисту: 30 Визначено частоту, з якою слід оцінювати ефективність заходів захисту: 30 Визначено персонал або ролі, яким повідомляється про стан безпеки системи: adminsecurity_officer Визначено частоту, з якою повідомляється про стан безпеки системи: 30 Визначено персонал або ролі, яким повідомляється про стан конфіденційності системи: adminsecurity_officer Визначено частоту, з якою повідомляється про стан конфіденційності системи: 30
УПРАВЛІННЯ КОНФІГУРАЦІЄЮ (СМ)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
34	id-spe-cm-1		СМ-1	Розроблено та задокументовано політику управління конфігурацією: default_deny_ruleabac_rule_1 Політика управління конфігурацією поширюється на персонал або ролі: adminsecurity_officer Розроблені та задокументовані процедури управління , що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією: default_deny_ruleabac_rule_1 Посадова особа призначається для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією; СМ-01(с)[01][01] переглядається та оновлюється поточна політика управління конфігурацією частота; СМ-01(с)[01][02] переглядається та оновлюється поточна політика управління конфігурацією після події; СМ-01(с)[02][01] переглядаються та оновлюються поточні процедури управління конфігурацією частота; СМ-01(с)[02][02] переглядаються та оновлюються поточні процедури управління конфігурацією після події; ЗНАЧЕННЯ конфігурацією: adminsecurity_officer Визначено персонал або ролі, на яких поширюється політика управління конфігурацією: adminsecurity_officer Визначено персонал або ролі, на яких поширюється процедури управління конфігурацією: adminsecurity_officer Визначено посадову особу, яка управляє розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією: adminsecurity_officer Визначено частоту, з якою переглядається та оновлюється поточна політика управління конфігурацією: default_deny_ruleabac_rule_1 Визначено події, після яких переглядається та оновлюється поточна політика управління конфігурацією: default_deny_ruleabac_rule_1 Визначено частоту, з якою переглядаються та оновлюються поточні процедури управління конфігурацією: 30 Визначено події, після яких переглядаються та оновлюються поточні процедури управління конфігурацією: loginlogoutfailed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
35	БАЗОВА КОНФІГУРАЦІЯ (СМ-2)		СМ-2, СМ-2(7)	Переглядаються та оновлюються базові налаштування системи частота: щорічно Визначено частоту налаштувань; перегляду та оновлення базових: 30 Системи або компоненти системи з конфігураціями видаються особам, що перебувають у місцях, які організація вважає, становлять значний ризик: adminsecurity_officer Заходи безпеки застосовуються до систем або компонентів системи, коли особи повертаються з поїздки: adminsecurity_officer Визначено системи або компоненти систем, які мають видаватися особам, що перебувають у місцях зі значним ризиком: adminsecurity_officer
36	УПРАВЛІННЯ ЗМІНАМИ КОНФІГУРАЦІЇ (СМ-3)		СМ-3	Записи про зміни конфігурації у системі зберігаються протягом <період часу СМ-03_ODP[01]>: 30 Визначено період часу, протягом якого зберігатимуться записи про зміни конфігурації: 30 Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {частота; коли умови}: Визначено частоту, з якою викликаються елементи управління змінами конфігурації (якщо вибрано): 30 Визначено умови, за яких викликаються елементи управління змінами конфігурації (якщо вибрано); СМ-03(а) визначено та задокументовано типи змін до системи, які контролюються конфігурацією:
37	id-spe-cm-4		СМ-4, СМ-4(2)	
38	ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ (СМ-5)		СМ-5	
39	НАЛАШТУВАННЯ КОНФІГУРАЦІЇ (СМ-6)		СМ-6	Зміни в налаштуваннях конфігурації відстежуються відповідно до політики та процедур організації: default_deny_ruleabac_rule_1 Зміни налаштувань конфігурації керуються відповідно до політики та процедур організації: default_deny_ruleabac_rule_1

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
40	id-spe-cm-7		CM-7, CM-7(1), CM-7(5)	Використання протоколи заборонено або обмежено: TLS 1.3 Визначено протоколи, які необхідно заборонити або обмежити; CM-07_ODP[05] визначено програмне забезпечення, яке необхідно заборонити або обмежити: TLS 1.3 Система переглядається частота для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг: TLS 1.3 Протоколи, які вважаються непотрібними та/або незахищеними, вимкнено: TLS 1.3 Визначено частоту, з якою слід переглядати систему для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг: TLS 1.3 Визначено протоколи, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними: TLS 1.3 Політика "заборонити все, дозволити за винятком" застосовується, щоб дозволити виконання авторизованих програм у системі: default_deny_ruleabac_rule_1 Переглядається та оновлюється список авторизованих програм частота: Визначено частоту перегляду та оновлення списку авторизованих програм: 30
41	ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ (CM-8)		CM-8, CM-8(1)	Переглядається та оновлюється опис компонентів системи частота: щорічно Визначено частоту перегляду та оновлення опису компонентів системи: 30
42	РОЗТАШУВАННЯ ІНФОРМАЦІЇ (CM-12)		CM-12	
ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ (CP)				
43	РЕЗЕРВНЕ КОПІЮВАННЯ (CP-9)		CP-9, CP-9(8)	Резервне копіювання інформації користувача, що міститься в компонентах системи, здійснюється частота: щорічно Виконується резервне копіювання інформації системи, що міститься в системі частота; CP-09(c) створюються резервні копії документації системи, включаючи документацію, пов'язану з безпекою та конфіденційністю частота: щорічно Визначено частоту, з якою слід проводити резервне копіювання інформації користувача відповідно до часу відновлення та цілей відновлення: 30 Визначено частоту проведення резервного копіювання інформації системи, що відповідає завдань відновлення і встановлених цілей відновлення: 30 Визначено частоту, з якою слід проводити резервне копіювання документації системи відповідно до часу відновлення та цілей точки відновлення: 30 Реалізовано криптографічні механізми для запобігання несанкціонованому розкриттю та зміні резервної інформації: AES-256-GCM
ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (IA)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
44	id-spe-ia-1		IA-1	Розроблено та задокументовано політику ідентифікації та автентифікації: default_deny_ruleabac_rule_1 Політика ідентифікації та автентифікації поширюється на персонал або ролі: adminsecurity_officer Розроблені та задокументовані процедури ідентифікації та автентифікації, що сприяють впровадженню політики ідентифікації та автентифікації, а також відповідні заходи ідентифікації та перевірки автентичності: default_deny_ruleabac_rule_1 Посадова особа призначається для управління політикою та процедурами ідентифікації та автентифікації; IA-01(c)[01][01] переглядається та оновлюється поточна політика ідентифікації та автентифікації частота; IA-01(c)[01][02] переглядається та оновлюється поточна політика ідентифікації та автентифікації після подій; IA-01(c)[02][01] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації частота; IA-01(c)[02][02] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації після подій: adminsecurity_officer Визначено персонал або ролі, на які поширюється політика ідентифікації та автентифікації: adminsecurity_officer Визначено персонал або ролі, на які поширюються процедури ідентифікації та автентифікації: adminsecurity_officer Визначено посадову особу, яка управляє політикою та процедурами ідентифікації та автентифікації: adminsecurity_officer Визначено частоту, з якою переглядається та оновлюється поточна політика ідентифікації та автентифікації: default_deny_ruleabac_rule_1 Визначено події, які потребують перегляду та оновлення поточної політики ідентифікації та автентифікації: default_deny_ruleabac_rule_1 Визначено частоту, з якою переглядаються та оновлюються поточні процедури ідентифікації та автентифікації: 30 Визначено події, які потребують перегляду та оновлення процедур ідентифікації та автентифікації: loginlogoutfailed_attempt
45	id-spe-ia-2		IA-2, IA-2(1), IA-2(2), IA-2(8)	
46	id-spe-ia-3		IA-3	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
47	УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ (IA-4)		IA-4, IA-4(4)	Управління ідентифікаторами здійснюється шляхом отримання дозволу від персоналу або ролей на призначення ідентифікатора особі, групі, ролі або пристрою: adminsecurity_officer Управління ідентифікаторами здійснюється шляхом вибору ідентифікатора, який ідентифікує окрему особу, групу, ролі або пристрій: adminsecurity_officer Управління ідентифікаторами здійснюється шляхом призначення ідентифікатора особі, групі, ролі або пристрою; IA-04(d) ідентифікатори управляються шляхом запобігання повторному використанню ідентифікаторів впродовж період часу: adminsecurity_officer Визначено персонал або ролі, від яких необхідно отримати дозвіл на призначення ідентифікатора: adminsecurity_officer Визначено період часу для запобігання повторному використанню ідентифікаторів: 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
48	АВТЕНТИФІКАТОР УПРАВЛІННЯ		IA-5, IA-5(1)	Управління системними автентифікаторами здійснюється шляхом перевірки, як частини початкового розподілу автентифікатора, особи, групи, ролі або пристрою, який отримує автентифікатор: adminsecurity_officer Управління системними автентифікаторами здійснюється шляхом зміни/оновлення автентифікаторів у встановлений період часу або коли відбуваються події: loginlogoutfailed_attempt Визначено період часу для зміни або оновлення автентифікаторів за типом автентифікатора: 30 Для автентифікації на основі паролів підтримується та оновлюється список часто використовуваних, очікуваних або скомпрометованих паролів частота, а також коли є підозра, що паролі організації були скомпрометовані прямо чи опосередковано: adminsecurity_officer Для автентифікації на основі паролів, коли паролі створюються або оновлюються користувачами, паролі перевіряються на відсутність у списку загальноновживаних, очікуваних або скомпрометованих паролів в IA-05(01)(a): adminsecurity_officer Для автентифікації на основі паролів, паролі передаються лише криптографічно захищеними каналами: adminsecurity_officer Для автентифікації на основі паролів паролі зберігаються за допомогою затвердженого алгоритму гешування, переважно використовуючи ключову геш-функцію: adminsecurity_officer Для автентифікації на основі пароля дозволяється вибір користувачем довгих паролів і фраз, що включають пробіли та всі друковані символи: adminsecurity_officer Для автентифікації на основі пароля використовуються автоматизовані інструменти, які допомагають користувачеві у виборі надійних автентифікаторів паролів: adminsecurity_officer Для автентифікації на основі пароля застосовуються склад та правила складності: default_deny_ruleabac_rule_1 Визначено частоту оновлення списку часто використовуваних, очікуваних або скомпрометованих паролів: adminsecurity_officer Визначено склад та правила складності автентифікатора: default_deny_ruleabac_rule_1
49	id-spe-ia-6		IA-6	Забезпечино приховану зворотну передачу інформації автентифікації в процесі автентифікації для забезпечення захисту інформації від можливої експлуатації та використання неавторизованими особами: adminsecurity_officer
50	ПОВТОРНА АВТЕНТИФІКАЦІЯ (IA-11)		IA-11	
РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
51	id-spe-ir-1		IR-1	Розроблено та задокументовано політику реагування на інциденти: default_deny_ruleabac_rule_1 Політика реагування на інциденти поширюється серед персоналу або ролей: adminsecurity_officer Розроблені та задокументовані процедури реагування на інциденти, що сприяють впровадженню політики реагування на інциденти та пов'язаних з нею заходів захисту з реагування на інциденти: default_deny_ruleabac_rule_1 Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур реагування на інциденти; IR-01(c)[01][01] переглядається та оновлюється поточна політика реагування на інциденти частота; IR-01(c)[01][02] поточна політика реагування на інциденти переглядається та оновлюється після подій; IR-01(c)[02][01] переглядаються та оновлюються поточні процедури реагування на інциденти частота; IR-01(c)[02][02] поточні процедури реагування на інциденти переглядаються та оновлюються після подій: adminsecurity_officer Визначено персонал або ролі, до яких має бути доведена політика реагування на інциденти: adminsecurity_officer Визначено персонал або ролі, до яких мають бути доведені процедури реагування на інциденти: adminsecurity_officer Визначено посадову особу, яка керуватиме політикою та процедурами реагування на інциденти: adminsecurity_officer Визначено частоту, з якою переглядається та оновлюється поточна політика реагування на інциденти: default_deny_ruleabac_rule_1 Визначаються події, які потребують перегляду та оновлення поточної політики реагування на інциденти: default_deny_ruleabac_rule_1 Визначено частоту, з якою переглядаються та оновлюються поточні процедури реагування на інциденти: 30 Визначено події, які потребують перегляду та оновлення процедур реагування на інциденти: loginlogoutfailed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
52	НАВЧАННЯ З РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-2)		IR-2	Навчання з реагування на інциденти надається користувачам системи відповідно до призначених ролей та обов'язків протягом періоду часу з моменту прийняття на себе ролі або обов'язків з реагування на інциденти або отримання доступу до системи: adminsecurity_officer Користувачам системи надається навчання з реагування на інциденти відповідно до призначених ролей та обов'язків частота: щорічно Зміст навчання з реагування на інциденти переглядається та оновлюється частота: щорічно Визначено частоту, з якою користувачі повинні проходити навчання з реагування на інциденти: 30 Визначено частоту перегляду та оновлення змісту навчання з реагування на інциденти: 30 Визначено події, які ініціюють перегляд змісту навчання з реагування на інциденти: loginlogoutfailed_attempt
53	ПЕРЕВІРКА РЕАГУВАНЬ НА ІНЦИДЕНТИ (IR-3)		IR-3	Ефективність реагування системи на інциденти перевіряється частота за допомогою тестів: щорічно Визначено частоту, з якою необхідно перевіряти ефективність реагування системи на інциденти: 30
54	Обробка інциденту (IR-4)		IR-4	
55	Моніторинг інциденту (IR-5)		IR-5	
56	ЗВІТНІСТЬ ПРО ІНЦИДЕНТИ (IR-6)		IR-6	Персонал зобов'язаний повідомляти про підозрілі інциденти протягом періоду часу: adminsecurity_officer Визначено період часу, протягом якого персонал повинен повідомляти про підозрілі інциденти до уповноваженого органу: adminsecurity_officer
57	ПІДТРИМКА РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-7)		IR-7	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
58	План реагування на інциденти (IR-8)		IR-8	Розроблено план реагування на інцидент, який розглядається та затверджується персоналом або ролями частота: adminsecurity_officer Розроблено план реагування на інциденти, в якому чітко визначено відповідальність за реагування на інциденти для організацій, персоналу або ролей: adminsecurity_officer Копії плану реагування на інцидент розповсюджуються серед <IR- 08 _ ODP[04] персоналу з реагування на інциденти>: adminsecurity_officer План реагування на інциденти оновлюється з урахуванням змін у системі та організації або проблем, що виникають під час впровадження, виконання або тестування плану: 30 Зміни в плані реагування на інцидент повідомляються персоналу з реагування на інциденти: adminsecurity_officer Визначено персонал або ролі, які переглядають та затверджують план реагування на інциденти: adminsecurity_officer Визначено періодичність перегляду та затвердження плану реагування на інциденти: щорічно Визначені організації, персонал або ролі, які несуть відповідальність за реагування на інциденти; IR-08 _ ODP[04] визначено персонал з реагування на інцидент (ідентифікований за іменами та/або за ролями), якому мають бути роздані копії плану реагування на інцидент: adminsecurity_officer Визначено персонал з реагування на інцидент (ідентифікований за іменами та/або ролями), якому повідомляються зміни до плану реагування на інцидент: adminsecurity_officer
ТЕХНІЧНЕ ОБСЛУГОВУВАННЯ (МА)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
59	id-sre-ma-1		МА-1	Розроблено та задокументовано політику технічного обслуговування: default_deny_ruleabac_rule_1 Політика технічного обслуговування поширюється на персонал або ролі: adminsecurity_officer Розроблені та задокументовані процедури технічного обслуговування, що сприяють впровадженню політики технічного обслуговування та пов'язаних з нею заходів технічного обслуговування: default_deny_ruleabac_rule_1 Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур технічного обслуговування; МА-01(c)[01][01] переглядається та оновлюється поточна політика обслуговування частота; МА-01(c)[01][02] переглядається та оновлюється поточна політика обслуговування після подій; МА-01(c)[02][01] переглядаються та оновлюються поточні процедури технічного обслуговування частота; МА-01(c)[02][02] переглядаються та оновлюються поточні процедури технічного обслуговування після подій: adminsecurity_officer Визначено персонал або ролі, на які поширюється політика технічного обслуговування: adminsecurity_officer Визначено персонал або ролі, на які поширюються процедури технічного обслуговування: adminsecurity_officer Визначено посадову особу, яка керуватиме політикою та процедурами технічного обслуговування: adminsecurity_officer Визначено частоту, з якою переглядається та оновлюється поточна політика технічного обслуговування: default_deny_ruleabac_rule_1 Визначено події, які потребують перегляду та оновлення поточної політики технічного обслуговування: default_deny_ruleabac_rule_1 Визначено частоту, з якою переглядаються та оновлюються поточні процедури технічного обслуговування: 30 Визначено події, які потребують перегляду та оновлення процедур технічного обслуговування: loginlogoutfailed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
60	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ (МА-3)		МА-3, МА-3(1), МА-3(2), МА-3(3)	Переглядаються раніше затверджені інструменти технічного обслуговування частота: щорічно Визначено частоту, з якою слід переглядати раніше затверджені інструменти технічного обслуговування: 30 Оглядаються інструменти для технічного обслуговування, які доставлені на об'єкт обслуговуючим персоналом, на предмет неправильних або несанкціонованих модифікацій: adminsecurity_officer Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом отримання дозволу від персонал або ролі: adminsecurity_officer Визначено персонал або ролі, які можуть надавати дозвіл на переміщення обладнання з об'єкту: adminsecurity_officer
61	ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ (МА-4)		МА-4	Впроваджено віддалені дії з обслуговування та діагностики: loginlogoutfailed_attempt Відстежуються віддалені дії з обслуговування та діагностики: loginlogoutfailed_attempt Використання віддалених засобів технічного обслуговування та діагностики дозволено лише відповідно до політики організації: default_deny_ruleabac_rule_1
62	ТЕХНІЧНИЙ ПЕРСОНАЛ (МА-5)		МА-5	Запроваджено процес авторизації технічного персоналу: adminsecurity_officer Ведеться перелік авторизованих організацій або персоналу з технічного обслуговування: adminsecurity_officer Персонал без супроводу, який виконує технічне обслуговування системи, має необхідні дозволи на доступ: adminsecurity_officer Персонал організації з необхідними повноваженнями доступу та технічною компетентністю призначений/призначені для нагляду за діяльністю з технічного обслуговування персоналу, який не має необхідних дозволів на доступ: adminsecurity_officer
ЗАХИСТ НОСІЇВ ІНФОРМАЦІЇ (МР)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
63	id-spre-mp-1		MP-1	Розроблено та задокументовано політику захисту носіїв інформації: default_deny_ruleabac_rule_1 Політика захисту носіїв інформації поширюється на персонал або ролі: adminsecurity_officer Розроблено та задокументовано процедури захисту носіїв інформації, що сприятимуть реалізації політики захисту носіїв інформації та заходів захисту носіїв інформації: default_deny_ruleabac_rule_1 Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур захисту носіїв інформації. MP-01(c)[01][01] переглядається та оновлюється поточна політика захисту носіїв інформації частота; MP-01(c)[01][02] переглядається та оновлюється поточна політика захисту носіїв інформації після подій; MP-01(c)[02][01] переглядаються та оновлюються поточні процедури захисту носіїв інформації частота; MP-01(c)[02][02] переглядаються та оновлюються поточні процедури захисту носіїв інформації після подій: adminsecurity_officer Визначено персонал або ролі, серед яких має бути поширена політика захисту носіїв інформації: adminsecurity_officer Визначено персонал або ролі, серед яких мають бути поширені процедури захисту носіїв інформації: adminsecurity_officer Визначено посадову особу, яка керуватиме політикою та процедурами захисту носіїв інформації: adminsecurity_officer Визначено частоту, з якою переглядається та оновлюється поточна політика захисту носіїв інформації: default_deny_ruleabac_rule_1 Визначено події, які потребують перегляду та оновлення чинної політики захисту носіїв інформації: default_deny_ruleabac_rule_1 Визначено частоту, з якою переглядаються та оновлюються чинні процедури захисту носіїв інформації: 30 Визначено події, які потребують перегляду та оновлення процедур захисту носіїв інформації: loginlogoutfailed_attempt
64	ДОСТУП ДО НОСІЇВ ІНФОРМАЦІЇ (MP-2)		MP-2	Доступ до типів цифрових носіїв інформації обмежено для персоналу або ролей: adminsecurity_officer Доступ до типів нецифрових носіїв інформації обмежено для персоналу або ролей: adminsecurity_officer Визначено персонал або ролі, уповноважені на доступ до цифрових носіїв інформації: adminsecurity_officer Визначено персонал або ролі, уповноважені на доступ до нецифрових носіїв інформації: adminsecurity_officer
65	МАРКУВАННЯ НОСІЇВ ІНФОРМАЦІЇ (MP-3)		MP-3	Визначено типи носіїв інформації, які звільняються від маркування під час перебування на контрольованих зонах: 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
66	ЗБЕРІГАННЯ НОСІВ ІНФОРМАЦІЇ (MP-4)		MP-4	
67	Транспортування носіїв інформації (MP-5)		MP-5	Типи носіїв інформації системи захищаються під час транспортування за межі контрольованих зон за допомогою заходів безпеки: 30 Типи носіїв інформації системи контролюються під час транспортування за межі контрольованих зон за допомогою заходів безпеки: 30 Під час транспортування за межі контрольованих зон ведеться облік носіїв інформації системи: 30 Визначено персонал, уповноважений здійснювати діяльність з транспортування носіїв інформації: adminsecurity_officer Діяльність, пов'язана з транспортуванням носіїв інформації системи, обмежується визначеним уповноваженим персоналом: adminsecurity_officer Визначено типи носіїв інформації системи для захисту та контролю під час транспортування за межі контрольованих зон: 30
68	id-spe-mp-6		MP-6	Застосовуються механізми очищення, надійність і цілісність яких відповідає категорії безпеки або рівню секретності інформації: автоматизований засіб моніторингу
69	ВИКОРИСТАННЯ НОСІВ ІНФОРМАЦІЇ (MP-7)		MP-7	
id-spe-pe				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
70	id-spe-pe-1		PE-1	Розроблено та задокументовано політику фізичного захисту та захисту робочого середовища: default_deny_ruleabac_rule_1 Політика фізичного захисту та захисту робочого середовища розповсюджується серед персоналу або ролей: adminsecurity_officer Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур фізичного захисту та захисту робочого середовища; PE-01(c)[01][01] переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища частота; PE-01(c)[01][02] поточна політика фізичного захисту та захисту робочого середовища переглядається та оновлюється після подій; PE-01(c)[02][01] переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища частота; поточні процедури фізичного та екологічного захисту переглядаються та оновлюються після подій. PE-01(c)[02][02]: adminsecurity_officer Визначено персонал або ролі, до яких має бути доведена політика фізичного захисту та захисту робочого середовища: adminsecurity_officer Визначено персонал або ролі, на які поширюються процедури фізичного захисту та захисту робочого середовища: adminsecurity_officer Визначено посадову особу, яка керуватиме політикою та процедурами фізичного захисту та захисту робочого середовища: adminsecurity_officer Визначено частоту, з якою переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища: default_deny_ruleabac_rule_1 Визначено події, які потребують перегляду та оновлення поточної політики фізичного захисту та захисту робочого середовища: default_deny_ruleabac_rule_1 Визначено частоту, з якою переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища: 30 Визначено події, які потребують перегляду та оновлення процедур фізичного захисту та захисту робочого середовища: loginlogoutfailed_attempt

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
71	РЕ-2 доступу (РЕ-2)		РЕ-2	Розроблено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система: Затверджено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система: Ведеться перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система: Переглядається список доступу, у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта частота: adminsecurity_officer Особи видаляються зі списку доступу до об'єкта, коли доступ більше не потрібен: adminsecurity_officer Визначено періодичність перегляду списку доступу, у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта: adminsecurity_officer
72	ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ		РЕ-3	Активність відвідувачів контролюється умови: Пристрої фізичного доступу інвентаризуються частота: щорічно Коди доступу змінюється частота, коли код скомпрометовано, або коли особи, які володіють кодом, переводяться або звільняються; <РЕ- РЕ-03(g)[02] ключі змінюються частота, коли ключі втрачено, або коли особи, що володіють ключами, переводяться або звільняються: adminsecurity_officer Визначено умови, що вимагають супроводу відвідувачів та моніторингу активності відвідувачів: Визначено частоту проведення інвентаризації пристроїв фізичного доступу: 30 Визначено частоту, з якою потрібно змінювати коди доступу: 30 Визначено частоту, з якою потрібно змінювати ключі: 30
73	РЕ-4 ліній електроживлення (РЕ-4)		РЕ-4	
74	id-spe-pe-5		РЕ-5	
75	МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ		РЕ-6	Переглядаються журнали фізичного доступу частота: щорічно Визначено частоту перегляду журналів фізичного доступу: 30 Визначено події або потенційні ознаки подій, що вимагають перегляду журналів фізичного доступу: loginlogoutfailed_attempt
76	АЛЬТЕРНАТИВНЕ РОБОЧЕ МІСЦЕ (РЕ-17)		РЕ-17	Визначаються заходи захисту, які будуть застосовуватися на альтернативних робочих місцях; РЕ-17(a) альтернативні робочі місця визначені та задокументовані; РЕ-17(b) заходи захисту впроваджені на альтернативних робочих місцях; РЕ-17(c) оцінюється ефективність заходів захисту на альтернативних робочих місцях; РЕ-17(d) працівникам надаються засоби комунікації з персоналом служби інформаційної безпеки на випадок інцидентів: adminsecurity_officer
ПЛАНУВАННЯ (PL)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
77	id-spe-pl-1		PL-1	Визначено персонал або ролі, до яких має бути доведена політика планування безпеки: adminsecurity_officer Визначено персонал або ролі, на які поширюватимуться процедури планування безпеки: adminsecurity_officer Визначено посадову особу, яка керуватиме політикою та процедурами планування безпеки: adminsecurity_officer Визначено періодичність перегляду та оновлення поточної політики планування безпеки: default_deny_ruleabac_rule_1 Є події, які потребують перегляду та оновлення поточної політики планування безпеки: default_deny_ruleabac_rule_1 Визначена частота, з якою переглядаються та оновлюються поточні процедури планування безпеки: щорічно

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
78	id-spe-pl-2		PL-2	Призначені особи або групи, з якими пов'язана діяльність з безпекою та конфіденційністю, що впливає на систему, яка потребує планування та координації: adminsecurity_officer Призначено персонал або ролі для отримання розповсюджуваних копій планів захисту інформації та конфіденційності системи: adminsecurity_officer Визначено періодичність перегляду інформації та конфіденційності системи; планів захисту PL-02a.01[01] розроблено план захисту інформації, архітектурі підприємства організації; який відповідає PL-02a.01[02] розроблено план конфіденційності для системи, відповідає архітектурі підприємства організації; який PL-02a.02[01] розроблено план захисту інформації, який чітко визначає складові компоненти системи; PL-02a.02[02] розроблено для системи план забезпечення конфіденційності, який чітко визначає складові компоненти системи; PL-02a.03[01] розроблено план захисту інформації системи, який описує операційний контекст системи з точки зору місії та бізнеспроцесів; PL-02a.03[02] розроблено для системи план забезпечення конфіденційності, який описує операційний контекст системи з точки зору місії та бізнес-процесів; PL-02a.04[01] розроблено план захисту інформації, який визначає осіб, що виконують системні ролі та обов'язки; PL-02a.04[02] розроблено для системи план забезпечення конфіденційності, який визначає осіб, що виконують ролі та обов'язки в системі; PL-02a.05[01] розроблено план захисту інформації, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.05[02] розроблено план конфіденційності для системи, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.06[01] розроблено план захисту інформації, який передбачає категоризацію безпеки системи, включаючи відповідне обґрунтування; PL-02a.06[02] розроблено для системи план забезпечення конфіденційності, який передбачає категоризацію системи за рівнем безпеки, включаючи обґрунтування; PL-02a.07[01] розроблено план захисту інформації, який описує будь-які конкретні загрози для системи, що викликають потенційні ризики для організації; PL-02a.07[02] розроблено план конфіденційності для системи, який описує будь-які конкретні загрози для системи, що викликають потенційні ризики для організації; PL-02a.08[01] розроблено план захисту інформації, який містить результати оцінки ризиків конфіденційності для систем, що обробляють інформацію, яка ідентифікує особу; PL-02a.08[02] розроблено для системи план забезпечення конфіденційності, який містить результати оцінки ризиків конфіденційності для систем, що обробляють інформацію, яка ідентифікує особу; PL-02a.09[01] розроблено план захисту інформації, який описує операційне середовище

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
79	ПРАВИЛА ПОВЕДІНКИ (PL-4)		PL-4	Визначено періодичність перегляду та оновлення правил поведінки: щорічно Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРА: {частота; коли правила переглядаються або оновлюються}: default_deny_ruleabac_rule_1 Визначена періодичність перегляду та повторного підтвердження правил поведінки (якщо вибрано); PL-04a.[01] встановлені правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та конфіденційності для осіб, яким потрібен доступ до системи; PL-04a.[02] надаються правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та конфіденційності, особам, які отримують доступ до системи; PL-04b. отримано перед наданням доступу до інформації та системи задокументоване підтвердження від таких осіб про те, що вони прочитали, зрозуміли та згодні дотримуватися правил поведінки; PL-04c. переглядаються та оновлюються правила поведінки частота; PL-04d. потрібно особам, які визнали попередню версію правил поведінки, прочитати та повторно визнати ЗНАЧЕННЯ ВИБРАНОГО ПАРАМЕТРА (ib): adminsecurity_officer
БЕЗПЕКА ПЕРСОНАЛУ (PS)				
80	id-spe-ps-1		PS-1	Визначено персонал або ролі, на які поширюється політика кадрової безпеки: adminsecurity_officer Визначено персонал або ролі, на які поширюються процедури кадрової безпеки: adminsecurity_officer Визначено посадову особу, яка керуватиме політикою та процедурами кадрової безпеки: adminsecurity_officer Визначена періодичність перегляду та оновлення поточної політики кадрової безпеки: default_deny_ruleabac_rule_1 Є події, які вимагають перегляду та оновлення поточної політики кадрової безпеки: default_deny_ruleabac_rule_1 Визначено періодичність перегляду та оновлення поточних процедур кадрової безпеки: щорічно
81	Перевірка персоналу (PS-3)		PS-3	Визначені умови, що вимагають повторної перевірки осіб: Визначена частота повторної перевірки осіб, для яких це показано; PS-03a. проходять особи перевірку перед тим, як надати їм доступ до системи; PS-03b.[01] проходять особи повторну перевірку відповідно до умови, що вимагають повторної перевірки; PS-03b.[02] проводиться повторна перевірка у випадках, коли це зазначено, частота: adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
82	Звільнення персоналу (PS-4)		PS-4	Визначено період часу, протягом якого забороняється доступ до системи: 30 Визначені теми інформаційної безпеки для обговорення під час проведення співбесід; PS-04a. при звільненні працівника доступ до системи вимикається протягом часового періоду; PS-04b. припиняють дію або анулюють будь-які автентифікатори та облікові дані після припинення трудових відносин з окремими особами; PS-04c. проводяться при звільненні окремих працівників співбесіди, які включають обговорення питань інформаційної безпеки; PS-04d. отримується після звільнення особи все майно, пов'язане з безпекою організаційної системи; PS-04e. зберігається доступ до організаційної інформації та систем, які раніше перебували під контролем особи, що звільняється, після припинення нею трудових відносин: adminsecurity _ officer
83	Переведення персоналу (PS-5)		PS-5	Визначені дії, які мають бути ініційовані після переведення або перепризначення: loginlogoutfailed _ attempt Визначено період часу, протягом якого мають бути здійснені дії з переведення або перепризначення після переведення або перепризначення: loginlogoutfailed _ attempt Визначено персонал або ролі, про які необхідно повідомляти, коли осіб призначають на інші посади або переводять на інші посади в організації: adminsecurity _ officer Визначено період часу, протягом якого необхідно повідомляти визначений організацією персонал або ролі, коли осіб перепризначають або переводять на інші посади в межах організації; PS-05a. переглядаються та підтверджуються поточні потреби в логічних та фізичних дозволах на доступ до систем та об'єктів при перепризначенні або переведенні осіб на інші посади в організації; PS-05b. були ініційовані дії з переведення або перепризначення протягом періоду часу після формальної дії з переведення; PS-05c. змінюється авторизація доступу за необхідності, щоб відповідати будь-яким змінам в оперативних потребах у зв'язку з перепризначенням або переведенням; PS-05d. було повідомлено персонал або ролі протягом часового періоду: adminsecurity _ officer
ОЦІНКА РИЗИКІВ (RA)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
84	id-spe-ra-1		RA-1	Визначено персонал або ролі, на які поширюється політика оцінювання ризику: adminsecurity_officer Визначено персонал або ролі, на які поширюються процедури, що сприяють здійсненню політики оцінювання ризику: adminsecurity_officer Визначена посадова особа, відповідальна за управління політикою та процедурами оцінювання ризику: adminsecurity_officer Визначена періодичність перегляду та оновлення поточної політики оцінювання ризику: default_deny_ruleabac_rule_1 Є події, які вимагають перегляду та оновлення поточної політики оцінювання ризику: default_deny_ruleabac_rule_1 Визначено періодичність перегляду поточних процедур оцінювання ризику: щорічно
85	ОЦІНЮВАННЯ РИЗИКУ (RA-3)		RA-3, RA-3(1)	Визначено періодичність оцінювання ризику: щорічно Визначено персонал або ролі, до яких мають бути доведені результати оцінювання ризику: adminsecurity_officer Визначена періодичність оновлення оцінювання ризику; перегляду результатів RA-03a.01 проводиться оцінювання ризику для виявлення загроз і вразливостей у системі; RA-03a.02 проводиться оцінювання ризику для визначення ймовірності та розміру шкоди від несанкціонованого доступу, використання, розкриття, порушення, модифікації або знищення системи; інформації, яку вона обробляє, зберігає або передає; а також будь-якої пов'язаної з нею інформації; RA-03a.03 проводиться оцінювання ризику для визначення ймовірності та впливу несприятливих наслідків для фізичних осіб, що виникають у зв'язку з обробкою інформації, яка ідентифікує особу; RA-03b. інтегровані результати оцінювання ризику та рішення з управління ризиками з точки зору організації та місії або бізнес-процесів з оцінкою ризиків на системному рівні; RA-03c. результати оцінювання ризику задокументовані в ЗНАЧЕННЯ ВИБРАНОВОГО ПАРАМЕТРА; RA-03d. переглядаються результати 03_ODP[03] частота>; RA-03e. поширюються результати оцінювання ризику серед персоналу або ролей; RA-03f. оновлюється оцінювання ризику частота або коли відбуваються значні зміни в системі, середовищі її функціонування або інших умовах, які можуть вплинути на стан безпеки або приватності системи оцінювання ризику <RA-: adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
86	СКАНУВАННЯ ВРАЗЛИВОСТЕЙ (RA-5)		RA-5, RA-5(2)	Визначена періодичність перевірки систем та розміщених на них застосунків на наявність вразливостей: щорічно Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику: 30 Потрібно ділитися інформацією, отриманою в процесі сканування вразливостей та оцінок контролю, з персоналом або ролями, з якими потрібно ділитися; RA-05a.[01] здійснюється моніторинг систем та розміщених застосунків на наявність вразливостей частота та/або випадковість відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05a.[02] перевіряються системи та розміщені застосунки на наявність вразливостей частота та/або випадковим чином відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05b. застосовуються інструменти та методи моніторингу вразливостей для забезпечення сумісності між інструментами; RA-05b.01 застосовуються інструменти та методи моніторингу вразливостей для автоматизації частини процесу управління вразливостями, використовуючи стандарти для переліку платформ, недоліків програмного забезпечення та неправильних конфігурацій; RA-05b.02 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частини процесу управління вразливостями шляхом використання стандартів для формування контрольних списків та процедур тестування; RA-05b.03 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частин процесу управління вразливостями шляхом використання стандартів для вимірювання впливу вразливостей; RA-05c. аналізуються звіти про сканування вразливостей та результати моніторингу вразливостей; RA-05d. усуваються легітимні вразливості час реагування відповідно до організаційної оцінки ризиків; RA-05e. надається інформація, отримана в процесі моніторингу вразливостей та оцінки контролю, персонал або ролі, щоб допомогти усунути подібні вразливості в інших системах; RA-05f. використовуються інструменти моніторингу вразливостей, які передбачають можливість швидкого оновлення вразливостей, що підлягають скануванню: adminsecurity_officer Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику: 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
87	РЕАГУВАННЯ НА РИЗИК (RA-7)		RA-7	
ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA)				
88	id-spe-sa-1		SA-1	Визначено персонал або ролі, на які поширюватиметься політика придбання систем і послуг: adminsecurity_officer Визначено персонал або ролі, на які поширюються процедури придбання систем і послуг: adminsecurity_officer Визначено посадову особу, яка керуватиме політикою та процедурами придбання систем і послуг: adminsecurity_officer Визначено періодичність перегляду та оновлення поточної політики придбання систем і послуг: default_deny_ruleabac_rule_1 Є події, які вимагають перегляду та оновлення поточної політики придбання систем і послуг: default_deny_ruleabac_rule_1 Визначено частоту, з якою переглядаються та оновлюються поточні процедури придбання систем і послуг: 30
89	id-spe-sa-8		SA-8	
90	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ (SA-9)		SA-9	Визначені засоби контролю, які будуть застосовуватися зовнішніми постачальниками системних послуг: автоматизований засіб моніторингу Визначені процеси, методи та техніки, що застосовуються для моніторингу дотримання вимог контролю зовнішніми постачальниками послуг; SA-09a.[01] дотримуються постачальники зовнішніх системних послуг вимог організаційної безпеки; SA-09a.[02] дотримуються постачальники зовнішніх системних послуг вимог приватності організації; SA-09a.[03] використовують постачальники зовнішніх системних послуг елементи керування; SA-09b.[01] визначено та задокументовано організаційний нагляд за зовнішніми системними послугами; SA-09b.[02] визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних сервісів; SA-09c. визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних послуг: adminsecurity_officer
91	id-spe-sa-22		SA-22	
ЗАХИСТ СИСТЕМ ТА КОМУНІКАЦІЙ (SC)				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
92	id-spe-sc-1		SC-1	Визначено персонал або ролі, до яких має бути доведена політика захисту системи та комунікацій: adminsecurity_officer Визначено персонал або ролі, на які поширюються процедури захисту системи та комунікацій: adminsecurity_officer Визначено посадову особу, яка керуватиме політикою та процедурами захисту системи та комунікацій: adminsecurity_officer Визначена періодичність перегляду та оновлення поточної політики захисту системи та комунікацій: default_deny_ruleabac_rule_1 Є події, які вимагають перегляду та оновлення поточної політики захисту системи та комунікацій: default_deny_ruleabac_rule_1 Визначена періодичність перегляду та оновлення поточних процедур захисту системи та засобів зв'язку: щорічно
93	id-spe-sc-4		SC-4	
94	ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)		SC-7, SC-7(5)	
95	id-spe-sc-8		SC-8, SC-8(1)	
96	ВІДКЛЮЧЕННЯ МЕРЕЖІ (SC-10)		SC-10	Визначено період бездіяльності, після якого система розриває мережеве з'єднання, пов'язане з сеансом зв'язку; SC08(05)_ODP[02] мережеве з'єднання, пов'язане з сеансом зв'язку, розірвано в кінці сеансу або після період часу бездіяльності: 30
97	ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)		SC-12	Встановлюються криптографічні ключі, коли в системі використовується криптографія відповідно до < SC-12_ODP вимог >: AES-256-GCM Здійснюється управління криптографічними ключами, коли в системі використовується криптографія, відповідно до вимог : AES-256-GCM
98	КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-13)		SC-13	КРИПТОГРАФІЧНИЙ ЗАХИСТ МЕТА ОЦІНКИ: Визначити, чи: AES-256-GCM Визначено використання криптографічних засобів: AES-256-GCM Визначено типи криптографії для кожного вказаного криптографічного використання; SC-13a. ідентифіковано використання>; SC-13b. реалізовано типи криптографії для кожного вказаного криптографічного використання (визначеного в SC-13_ODP[01]). криптографічне <SC-13_ODP[01]: AES-256-GCM
99	id-spe-sc-15		SC-15	
100	МОБІЛЬНИЙ КОД (SC-18)		SC-18	
101	АВТЕНТИФІКАЦІЯ СЕСІЇ (SC-23)		SC-23	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
102	ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ (SC-28)		SC-28, SC-28(1)	Реалізовані криптографічні механізми для запобігання несанкціонованому розкриттю інформації, що знаходиться в стані спокою на системних компонентах або носіях: AES-256-GCM Реалізовані криптографічні механізми для запобігання несанкціонованій модифікації інформації, що знаходиться в стані спокою на системних компонентах або носіях: AES-256-GCM
ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ (SI)				
103	id-spe-si-1		SI-1	Визначено персонал або ролі, до яких має бути доведена політика цілісності системи та інформації: adminsecurity_officer Визначено персонал або ролі, на які поширюються процедури цілісності системи та інформації : adminsecurity_officer Визначено посадову особу, відповідальну за управління системою та політикою і процедурами цілісності інформації: adminsecurity_officer Визначено періодичність перегляду та оновлення поточної політики цілісності системи та інформації: default_deny_ruleabac_rule_1 Є події, які вимагають перегляду та оновлення поточної політики цілісності системи та інформації: default_deny_ruleabac_rule_1 Визначено частоту, з якою переглядаються та оновлюються поточні цілісності системи та інформації: 30
104	ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2)		SI-2	Визначено період часу, протягом якого необхідно встановити оновлення програмного забезпечення, пов'язані з безпекою, після виходу оновлень; SI-02a.[01] виявлено недоліки системи; SI-02a.[02] повідомляється про недоліки системи; SI-02a.[03] виправлені недоліки системи; SI-02b.[01] перевіряються оновлення програмного забезпечення, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[02] перевіряються оновлення програмного забезпечення, пов'язані з виправленням дефектів, на наявність потенційних побічних ефектів перед встановленням; SI-02b.[03] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[04] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на наявність потенційних побічних ефектів перед встановленням; SI-02c.[01] встановлено оновлення програмного забезпечення, що стосуються безпеки, протягом часовий проміжок з моменту випуску оновлень; SI-02c.[02] встановлено оновлення мікропрограми, що стосуються безпеки, протягом часового періоду з моменту випуску оновлень; SI-02d. включено відновлення порушених прав у процес управління організаційною конфігурацією: 30

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
105	ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ (SI-3)		SI-3	Визначено частоту, з якою механізми шкідливого коду виконують сканування: 30 Визначено дії, яких слід вжити у відповідь на виявлення шкідливого коду (якщо вибрано): loginlogoutfailed_attempt
106	МОНІТОРИНГ СИСТЕМИ (SI-4)		SI-4, SI-4(4)	Визначені методи та способи, що використовуються для виявлення несанкціонованого використання системи: adminsecurity_officer Визначена інформація про моніторинг системи, яка повинна надаватися персоналу або ролям: adminsecurity_officer Визначено персонал або ролі, яким має надаватися інформація про моніторинг системи: adminsecurity_officer Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {за потребою; частота}: щорічно Визначені критерії незвичної або несанкціонованої діяльності або умови для вхідного трафіку зв'язку: Визначені критерії незвичайної або несанкціонованої діяльності або умови для вихідного трафіку зв'язку: Здійснюється моніторинг вхідного комунікаційного трафіку частота на предмет незвичних або несанкціонованих дій або умов: щорічно Контролюється вихідний трафік зв'язку частота на предмет незвичних або несанкціонованих дій або умов. вихідного виявлення: щорічно
107	id-spe-si-5		SI-5	Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {персонал або ролі; елементи; зовнішні організації}: adminsecurity_officer Визначено персонал або ролі, до яких мають бути доведені попередження, поради та директиви з безпеки (якщо визначено): adminsecurity_officer
108	id-spe-si-12		SI-12	Здійснюється управління інформацією в системі відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог: default_deny_ruleabac_rule_1 Зберігається інформація в системі відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог: default_deny_ruleabac_rule_1 Управління інформацією, що виводиться з системи, здійснюється відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та операційних вимог: default_deny_ruleabac_rule_1 Зберігається інформація, що виводиться з системи, відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог: default_deny_ruleabac_rule_1
id-spe-sr				

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
109	id-spe-sr-1		SR-1	Визначено персонал або ролі, на які поширюється політика управління ризиками ланцюга постачання: adminsecurity_officer Визначено персонал або ролі, на які поширюються процедури управління ризиками ланцюга постачання: adminsecurity_officer Визначена посадова особа, відповідальна за розробку, документування та розповсюдження політики та процедур управління ризиками ланцюга постачання: adminsecurity_officer Визначена періодичність перегляду та оновлення поточної політики управління ризиками ланцюга постачання: default_deny_ruleabac_rule_1 Є події, які вимагають перегляду та оновлення поточної політики управління ризиками ланцюга постачання: default_deny_ruleabac_rule_1 Визначена періодичність перегляду та оновлення поточної процедури управління ризиками ланцюга постачання: щорічно
110	id-spe-sr-2		SR-2	

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
111	id-spe-sr-3		SR-3	Визначено персонал ланцюга поставок, з яким необхідно координувати процес або процеси виявлення та усунення слабких місць або недоліків в елементах і процесах ланцюга постачання: adminsecurity_officer Визначені засоби контролю ланцюга постачання, що застосовуються для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання: автоматизований засіб моніторингу Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {плани безпеки та конфіденційності; план управління ризиками ланцюга постачання; документ}; SR-03_ODP[05] визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання системи або компонента системи координується/координуються з персоналом ланцюга постачання; SR-03b. застосовуються засоби контролю ланцюга постачання для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання; SR-03c. задокументовані обрані та впроваджені процеси та засоби контролю ланцюга постачання в ЗНАЧЕННЯ ВИБІРКОВОГО ПАРАМЕТРА(ів): adminsecurity_officer Визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання системи або компонента системи координується/координуються з персоналом ланцюга постачання; SR-03b. застосовуються засоби контролю ланцюга постачання для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання; SR-03c. задокументовані обрані та впроваджені процеси та засоби контролю ланцюга постачання в ЗНАЧЕННЯ ВИБІРКОВОГО ПАРАМЕТРА(ів): adminsecurity_officer

№ з/п	Назва дії з безпеки інформації	Зміст дії	Заходи захисту	Мінімальні необхідні параметри
112	id-spe-sr-5		SR-5	
113	ОЦІНКА ПОСТАЧАЛЬНИКІВ (SR-6)		SR-6	Оцінюються та аналізуються ризики, пов'язані з ланцюгом постачання, які стосуються постачальників або підрядників та систем, компонентів системи або системних послуг, які вони надають < SR-06 _ ODP частота >: щорічно Визначена періодичність оцінки та аналізу ризиків, пов'язаних з ланцюгом постачання, що стосуються постачальників або підрядників, а також систем, компонентів системи або системних послуг, які вони надають: щорічно